Penetration Testing Report

Footprinting and Network Scanning

Week 2 Project: W2-PM4 (theHarvester) and W2-PM5 (Zenmap)

Prepared by	Remeldar Mashamaite
Programme	Networkwalks Cybersecurity Internship, Week 2
Testing dates	9 to 10 November 2026
Report date	11 November 2026
Classification	Educational lab exercise

Contents

1. Letter of Authorization
2. Executive Summary
3. Scope and Methodology
4. Module W2-PM4: theHarvester Footprinting
5. Module W2-PM5: Zenmap Network Scanning
6. Findings and Risk Ratings
7. Recommendations
8. Conclusion
9. References

1. Letter of Authorization

Prepared by: Remeldar Mashamaite
Date of letter: 11 November 2026

This letter records the scope and permission for the security testing carried out for Week 2 project modules W2-PM4, W2-PM5 and W2-PM-FINAL. The testing is for educational purposes only.

Target	Type	Owner / authorizer	Permitted activity
Metasploitable2 virtual machine, 10.0.0.3 (isolated VirtualBox NAT Network 10.0.0.0/24)	Intentionally vulnerable lab system	Remeldar Mashamaite (lab owner)	Host discovery, port scanning, service and OS detection with Nmap/Zenmap
vulnweb.com (public test sites)	Public site provided for security testing and training	Acunetix, which publishes the site for testing	Passive information gathering only, using theHarvester with public sources

Testing window: Zenmap scans 9 to 10 November 2026; theHarvester footprinting 10 November 2026.

Rules of engagement:

- Testing stayed within the targets and activities listed above.
- No exploitation, denial-of-service, password attacks or data modification were performed.
- No active scanning was directed at vulnweb.com or any system outside the lab network.
- Results are used only for this report.

Declaration: I confirm that I own and control the lab environment listed above, that the public target was queried through passive sources only, and that the activities were carried out within the scope set out in this letter.

Tester signature: R.mashamaite _____ Date: _____

Remeldar Mashamaite

2. Executive Summary

This report covers two Week 2 modules. The first, W2-PM4, used theHarvester to gather publicly available information about the domain vulnweb.com using passive sources. The second, W2-PM5, used Zenmap (the graphical front-end for Nmap) to scan an isolated Metasploitable2 lab machine at 10.0.0.3.

Key results

- theHarvester returned **90 hostnames** for vulnweb.com and no results from Shodan. Many names resolve to the same address (44.228.249.3).
- The Zenmap intense scan found **23 open TCP ports** on 10.0.0.3, including FTP, SSH, Telnet, SMTP, DNS, HTTP, Samba, NFS, MySQL, PostgreSQL, VNC, IRC and Tomcat.
- Several services are outdated or known to be dangerous, including vsftpd 2.3.4, Samba 3.0.x, an unauthenticated root shell on port 1524 and cleartext remote-access services (Telnet, rexec, rlogin, rsh).
- Metasploitable2 is deliberately vulnerable, so these findings are expected. The report treats them as it would a real exposed server.

3. Scope and Methodology

Environment: Kali Linux virtual machine (10.0.0.15) and Metasploitable2 virtual machine (10.0.0.3) on a VirtualBox NAT Network (10.0.0.0/24), isolated from other networks.

Tools: theHarvester 4.11.1, Zenmap/Nmap 7.991 on Kali Linux.

Approach:

- Passive footprinting of vulnweb.com with theHarvester, using public data sources only.
- Four Zenmap scans of the lab machine, moving from host discovery to full port-range scanning.
- Review of the service and version results, and risk rating of each exposed service.

Limitations: Results reflect the state of the lab on the dates tested. Risk ratings are the author's assessment for a lab exercise. Version-based risks should be confirmed before relying on them. The findings table is based on the Intense scan service table.

4. Module W2-PM4: theHarvester Footprinting

Objective: collect publicly available information (hostnames and IP addresses) about a target domain without touching the target directly.

Target: vulnweb.com (public test site, passive sources only)

Command used:

```
theHarvester -d vulnweb.com -l 100 -b crtsh,hackertarget,rapiddns,duckduckgo -f
harvester-results
```

The sources are public databases (certificate transparency logs, DNS datasets and a search engine). The -f option saved the results as XML and JSON files.

Results

- **90 hostnames** found. Shodan returned no results.
- Sample entries: antivirus1.vulnweb.com, autoconfig.vulnweb.com, baidu.vulnweb.com and bing.com.vulnweb.com, all resolving to **44.228.249.3** (also shown as the IPv6 form 64:ff9b::2ce4:f903).
- Several generated-looking names such as 0-30.ap-northeast-1.compute.vulnweb.com also resolve to 44.228.249.3. This suggests the domain uses a wildcard DNS record, so the hostname count probably overstates the number of distinct systems. This should be confirmed.

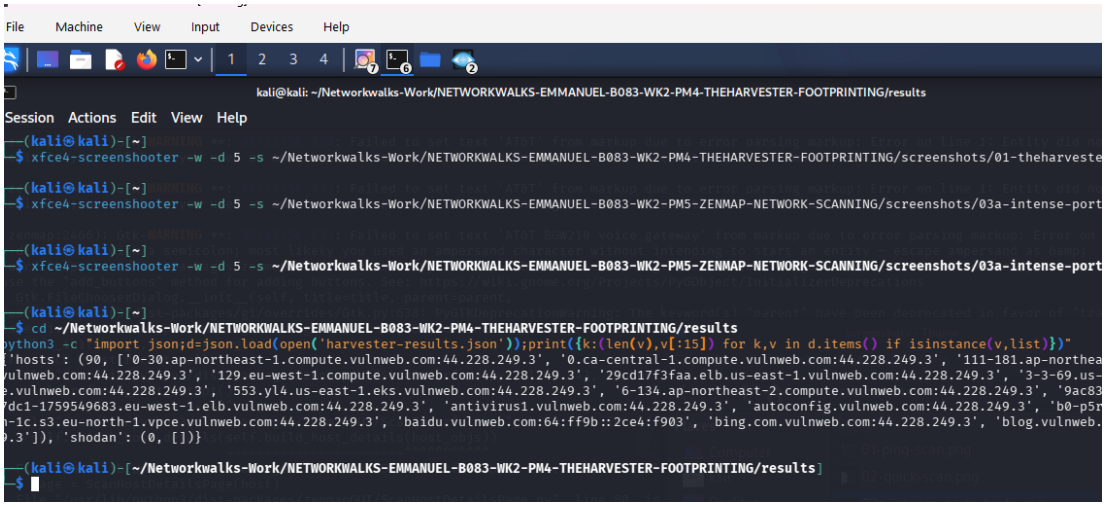


Figure 1: theHarvester JSON results summary (90 hosts, Shodan 0)

Risk and recommendation

Public DNS and certificate records reveal how an organisation names and hosts its systems, which helps an attacker map the target before any contact. Recommended: remove unused DNS records, avoid wildcard records where not needed, and review certificate transparency logs for unexpected hostnames.

5. Module W2-PM5: Zenmap Network Scanning

Objective: identify live hosts, open ports, services and versions on the lab target. **Target:** Metasploitable2, 10.0.0.3.

#	Scan	Command	Purpose
1	Ping scan	nmap -sn 10.0.0.3	Confirm the host is up
2	Quick scan	nmap -T4 -F 10.0.0.3	Fast scan of the 100 most common ports
3	Intense scan	nmap -T4 -A -v 10.0.0.3	Service versions, OS detection, default scripts, traceroute
4	Intense scan, all TCP ports	nmap -p 1-65535 -T4 -A -v 10.0.0.3	Check all 65,535 TCP ports

5.1 Scan 1: Ping scan

The host was up with MAC address 08:00:27:F2:FF:4C (Oracle VirtualBox virtual NIC). The scan took 0.89 seconds.

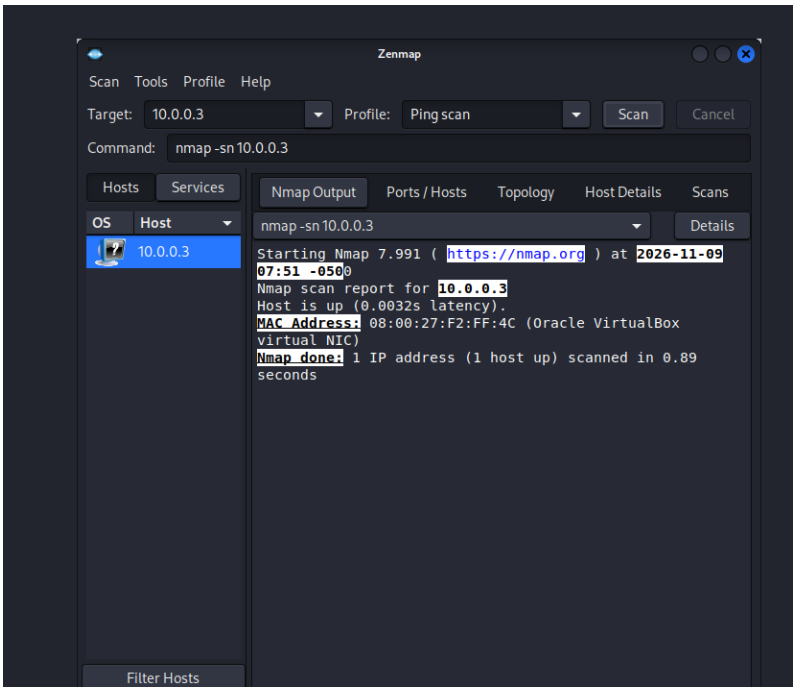


Figure 2: Ping scan of 10.0.0.3

5.2 Scan 2: Quick scan

The quick scan found 18 open ports in 1.02 seconds: 21, 22, 23, 25, 53, 80, 111, 139, 445, 513, 514, 2049, 2121, 3306, 5432, 5900, 6000 and 8009.

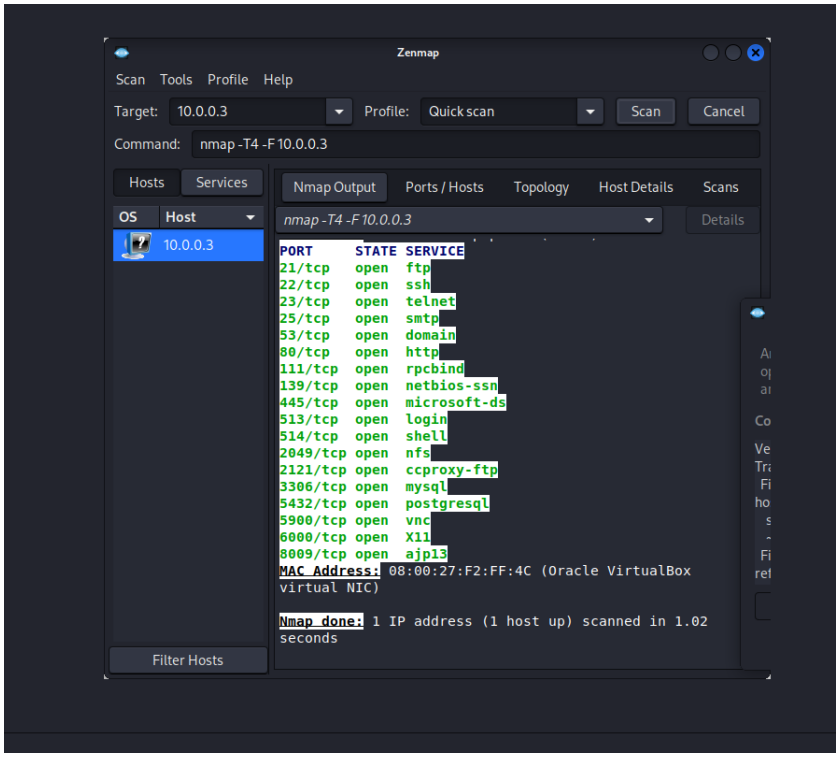


Figure 3: Quick scan results

5.3 Scan 3: Intense scan

The intense scan identified a Linux host and gathered service versions and script output. It completed in 74.72 seconds. The service table is in section 6. The screenshot shows the end of the output (SMB security mode, traceroute and scan summary).

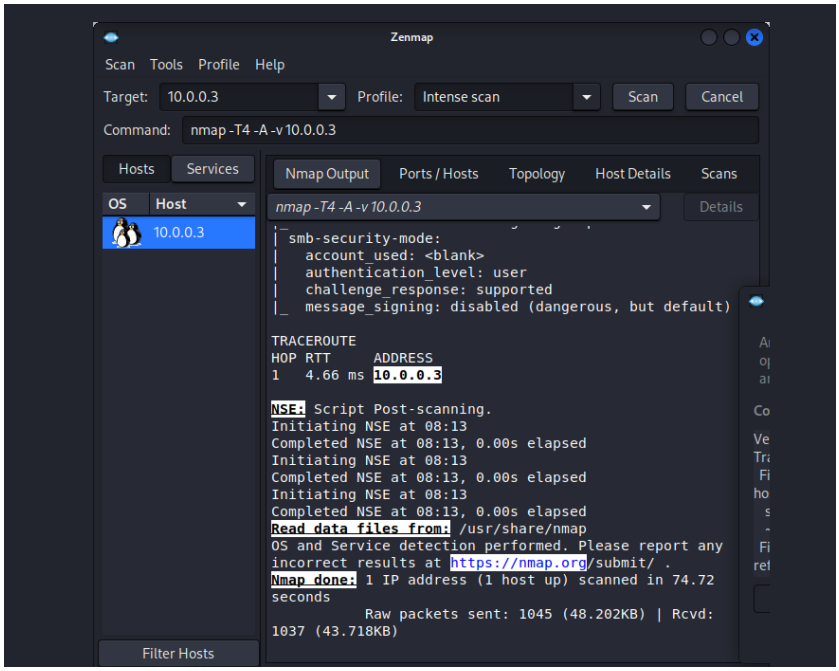


Figure 4: Intense scan output

5.4 Scan 4: Intense scan, all TCP ports

The full-range scan (ports 1 to 65535) completed in 54.63 seconds, sending 65,586 packets. It was run to check for services outside the default port list.

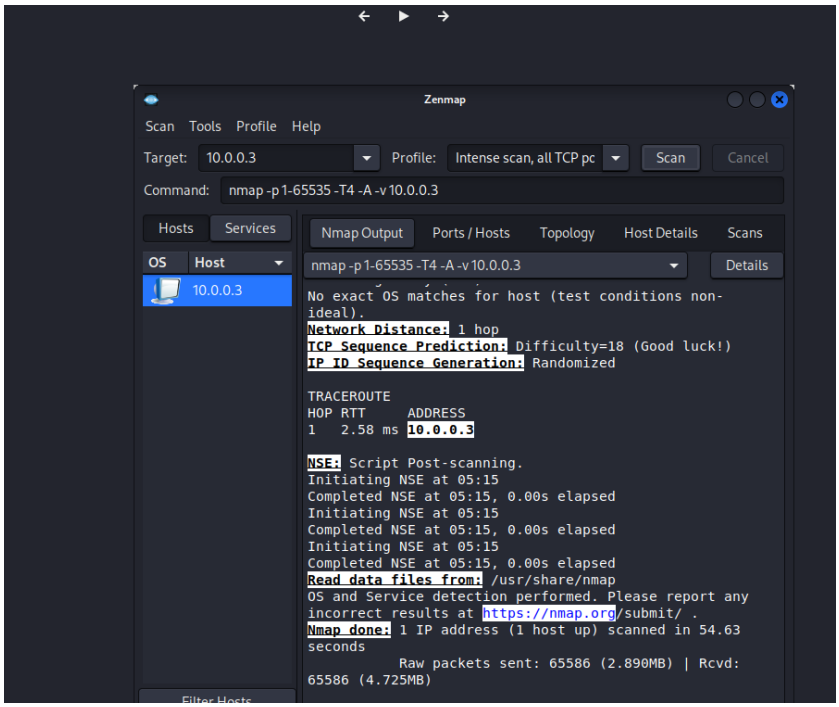


Figure 5: Intense scan of all TCP ports

6. Findings and Risk Ratings

The table lists the 23 open ports from the Intense scan. Ratings are the author's assessment for a lab exercise (Critical, High, Medium, Low).

Port	Service and version	Risk	Issue	Recommendation
21	FTP, vsftpd 2.3.4	Critical	This release is known to contain a backdoor (CVE-2011-2523). FTP sends credentials in cleartext.	Upgrade or remove; use SFTP.
22	SSH, OpenSSH 4.7p1 Debian 8ubuntu1	Medium	Very old version with known weaknesses.	Upgrade; use key authentication; restrict access.
23	Telnet, Linux telnetd	High	Cleartext remote login exposes passwords.	Disable; use SSH.
25	SMTP, Postfix smtpd	Medium	Mail service exposed; risk of relay abuse and user enumeration.	Restrict relaying; update; limit exposure.
53	DNS, ISC BIND 9.4.2	Medium	Outdated BIND with known vulnerabilities.	Upgrade; restrict zone transfers and recursion.
80	HTTP, Apache httpd 2.2.8	High	Outdated web server; web applications likely vulnerable.	Upgrade; patch; harden configuration.
111	rpcbind 2 (RPC 100000)	Medium	Exposes RPC service information.	Block externally; disable if unused.
139	NetBIOS, Samba smbd 3.X to 4.X	High	SMB exposure and outdated Samba.	Upgrade Samba; restrict SMB to trusted hosts.
445	SMB, Samba smbd 3.0.20	Critical	Samba 3.0.20 is affected by a known remote command execution flaw (CVE-2007-2447). Message signing disabled.	Upgrade Samba; enable signing; restrict access.
512	exec, netkit-rsh rexecd	High	Legacy remote execution with weak, cleartext authentication.	Disable; use SSH.
513	login (rlogin)	High	Legacy remote login with weak trust model.	Disable; use SSH.
514	tcpwrapped (rsh/shell)	High	Legacy remote shell service.	Disable; use SSH.
1099	Java RMI, GNU Classpath grmiregistry	High	Exposed RMI registry can allow remote code execution if misconfigured.	Block access; disable if unused.
1524	bindshell, Metasploitable root shell	Critical	Open shell with root access and no authentication.	Remove immediately; investigate how it was installed.
2049	NFS, versions 2 to 4	High	File shares may be mountable by untrusted hosts.	Restrict exports; require authentication.
2121	FTP, ProFTPD 1.3.1	High	Outdated FTP server with known vulnerabilities; cleartext.	Upgrade or remove; use SFTP.
3306	MySQL 5.0.51a-3ubuntu	High	Database exposed to the network; outdated.	Bind to localhost; upgrade; strong credentials.
5432	PostgreSQL 8.3.0 to 8.3.7	High	Database exposed; very old version.	Restrict access; upgrade.
5900	VNC (protocol 3.3)	High	Weak authentication; remote desktop exposed.	Tunnel through SSH; strong password; restrict.
6000	X11 (access denied)	Low	X server reachable, but access was denied.	Block externally.
6667	IRC, UnrealIRCd	Critical	Some UnrealIRCd 3.2.8.1 builds contain a known backdoor (CVE-2010-2075). Exact version not shown by the scan.	Confirm version; remove or replace.
8009	AJP13, Apache Jserv (protocol 1.3)	Medium	AJP connector exposed; should not be reachable externally.	Disable or restrict to the front-end server.
8180	HTTP, Apache Tomcat/Coyote JSP engine 1.1	High	Old Tomcat; management interface often has weak or default credentials.	Upgrade; secure or disable the manager application.

7. Recommendations

- **Remove or isolate critical services first:** the root shell on 1524, the backdoored vsftpd 2.3.4, UnrealIRCd and the vulnerable Samba version.
- **Replace cleartext remote access** (Telnet, rexec, rlogin, rsh, FTP) with SSH and SFTP.
- **Patch and upgrade** Apache, BIND, OpenSSH, MySQL, PostgreSQL, Tomcat and ProFTPD to supported versions.
- **Reduce the attack surface:** close unused ports, bind databases to localhost, and use a firewall to limit access to trusted hosts.
- **Harden authentication:** change default credentials, use strong passwords or keys, and restrict VNC and management interfaces.
- **Limit public information exposure:** remove unused DNS records, avoid wildcard DNS where not needed, and monitor certificate transparency logs.

8. Conclusion

Passive footprinting with theHarvester showed how much infrastructure information about a domain is available from public sources alone, with 90 hostnames found for vulnweb.com. Zenmap scanning of the Metasploitable2 lab machine found 23 open ports, many running outdated or known-vulnerable software, which is the expected result for a deliberately vulnerable system. Together, the two modules show the first stages of a penetration test: gather public information, then identify exposed services and rate their risk.

9. References

- Nmap reference guide: https://nmap.org/book/man.html
- theHarvester project: https://github.com/laramies/theHarvester
- Rapid7 Metasploitable2 documentation: https://docs.rapid7.com/metasploit/metasploitable-2/
- Networkwalks Week 2 project instructions: https://www.networkwalks.com
- Sample penetration testing report: https://github.com/waqaskarimccie/Pentesting-Report-Sample